

管理员操作手册

本手册面向 Portal Extension 管理员,涵盖账号管理、用户组、分享页、授权、会话查看与审计日志等全部后台操作。

每章先讲概念(理解 why),再讲操作步骤(怎么做),最后列注意事项。
深入的产品定位与系统原理见 [产品白皮书](#)。

目录

- 1. [快速入门](#)
- 2. [登录与登出](#)
- 3. [用户管理](#)
- 4. [用户组管理](#)
- 5. [分享页管理](#)
- 6. [授权管理](#)
- 7. [会话管理](#)
- 8. [审计日志](#)

1. 快速入门

本章带您走一遍典型工作流:创建用户 → 创建分享页 → 授权 → 用该用户登录验证。
完成后您将理解整个权限控制流程。

步骤 1:登录管理后台

用管理员账号(默认 `admin`)登录门户。登录后,左侧 sidebar 可见"管理后台"分组,包含用户管理、用户组管理、分享页管理、授权管理、会话管理、审计日志六个入口。

步骤 2:创建一个普通用户

进入 sidebar 「用户管理」→ 在创建用户表单填写用户名、邮箱、初始密码 → 点「创建」。
新用户出现在列表中,状态为"已启用"。

步骤 3:创建一个分享页

进入 sidebar 「分享页管理」→ 填写分享页名称和 RAGFlow 资源 ID → 点「创建」。

RAGFlow 资源 ID 是 RAGFlow 中 Chat(或 Agent)的 ID。在 RAGFlow 管理界面的 Chat 配置页可以找到,形如 `a1b2c3d4e5f6...`。

步骤 4:授权

进入 sidebar 「授权管理」→ 选择刚创建的分享页 → 主体类型选「用户」→ 授权对象选择刚创建的用户 → 点「授权」。

步骤 5:用新用户登录验证

登出管理员账号 → 用新用户的用户名和初始密码登录 → 在分享页列表中应能看到刚授权的分享页 → 点「打开」进入对话 → 发一条消息验证对话正常。

如果看不到分享页,检查授权是否成功(回到授权管理页查看授权列表)。

2. 登录与登出

2.1 登录

访问门户地址(如 `http://<server>/portal/`),输入用户名和密码登录。

- 管理员默认用户名 `admin`,密码由部署时的 `PORTAL_ADMIN_PASSWORD` 环境变量配置
- 登录失败会明确提示原因:"用户未注册" / "密码错误" / "账号已禁用"
- 登录成功后写 `login_success` 审计日志;失败写 `login_failure`

2.2 登出

点击右上角头像菜单中的「登出」按钮。登出后 session cookie 清除,需要重新登录。

2.3 注意事项

- 禁用用户的 session cookie 即使未过期,网关每次请求也会校验 `enabled` 状态,禁用后调网关返回 403——即"管理员禁用某用户后,该用户即使浏览器还开着也会立即失去对话能力"
- 如果部署了 OIDC SSO,登录页会显示 SSO 按钮,点击后跳转到 IdP 完成登录

3. 用户管理

3.1 概念

Portal Extension 有自己的账号体系,独立于 RAGFlow 租户。每个门户用户:

- 有用户名、邮箱、密码(密码用 bcrypt 哈希存储,不存明文)
- 有 `is_admin`(平台管理员)和 `org_admin`(org 级管理员)两种管理角色
- 有 `enabled` 状态(禁用后无法登录,已有 session 也会被拒绝)
- 归属一个 `org_id`(多租户隔离,默认 `default`)

管理员可以创建/启用/禁用/删除用户,以及重置用户密码。

3.2 创建用户

1. 进入 sidebar 「用户管理」
2. 在页面顶部的创建表单填写:
 - **用户名**:登录用,必须唯一
 - **邮箱**:用户标识,用于显示
 - **初始密码**:用户首次登录用此密码,登录后无法自行修改(需管理员重置)
3. 点「创建」按钮

新用户立即出现在列表中。创建用户不写审计日志(非敏感操作)。

3.3 启用/禁用用户

在用户列表中,每行操作列有「禁用」/「启用」按钮:

- 点「禁用」:用户立即无法登录,已有 session 调网关返回 403
- 点「启用」:恢复登录能力

启用/禁用写审计日志(`user_enable` / `user_disable`)。

注意:管理员账号(`is_admin=true`)不可禁用或删除(按钮禁用,带提示)。

3.4 重置密码

1. 在用户列表中,点该用户行的「改密码」按钮
2. 弹窗中输入新密码(不能为空)
3. 点「保存密码」

重置密码写审计日志(`user_password_change`),记录操作者与目标用户。

注意:用户无法自行修改密码,所有密码修改都需管理员操作。重置密码后,用户的 session cookie 不受影响(不会强制登出),但下次登录需用新密码。

3.5 删除用户(硬删除)

1. 在用户列表中,点该用户行的「删除」按钮
2. 弹窗确认:提示"将级联删除该用户的所有会话,不可恢复"
3. 确认后执行硬删除

硬删除会:

- 删除用户记录
- 清理该用户的组成员关系
- 级联删除该用户的所有会话(门户侧归属记录 + RAGFlow 侧 API4Conversation; RAGFlow 删除失败的会话也硬删门户侧记录,避免孤儿)

注意:

- 删除不可恢复——用户的会话、授权、审计日志关联都会清理
- 管理员账号不可删除
- 如果只是想暂停用户访问,用「禁用」而非「删除」

4. 用户组管理

4.1 概念

用户组用于按组批量授权。把一个分享页授权给用户组后,组内所有成员继承 use 权限。适合按部门/项目批量管理访问权。

- 用户组有名称,归属一个 `org_id`
- 一个用户可以属于多个组
- 组成员关系可以随时添加/移除,授权即时生效

4.2 创建用户组

1. 进入 sidebar 「用户组管理」
2. 在创建表单中填写用户组名称

3. 点「创建」

4.3 添加/移除成员

在用户组列表中,每个组展开后可见成员列表:

- **添加成员**:从下拉框选择用户 → 点「添加」(幂等,重复添加不会报错)
- **移除成员**:点成员行右侧的「移除」按钮

移除成员后,该用户立即失去通过该组继承的授权(网关每次请求校验 grant)。

4.4 注意事项

- 用户组当前不支持删除(一旦创建即永久存在)——如果不再需要某个组,移除所有成员即可使其授权失效
- 用户硬删除时,会自动清理其在所有组中的成员关系

5. 分享页管理

5.1 概念

分享页是用户能看到的对话入口,对应 RAGFlow 中的一个 Chat(dialog)或 Agent。
每个分享页:

- 有名称(显示给用户,建议用业务可读名,如"法务知识库")
- 有关联的 RAGFlow 资源 ID(dialog_id 或 agent_id)
- 有类型(chat / agent)和嵌入方式(fullscreen / widget)
- 有 `enabled` 状态(禁用后用户看不到该分享页)
- 有 `is_public` 开关(公开分享页免登录访问,详见白皮书 §4.1)

用户在分享页列表只能看到:已授权(`enabled=true`)的分享页。

5.2 创建分享页

1. 进入 sidebar 「分享页管理」
2. 填写:
 - **分享页名称**:用户看到的名称
 - **RAGFlow 资源 ID**:RAGFlow Chat/Agent 的 ID
3. 点「创建」

如何获取 RAGFlow 资源 ID:在 RAGFlow 管理界面,进入对应 Chat 或 Agent 的配置页,URL 中 `id=` 后面的字符串即为资源 ID。鼠标悬浮在输入框上可看到完整提示。

5.3 启用/禁用分享页

在列表中间点「禁用」/「启用」按钮:

- 禁用后,该分享页不再出现在用户的分享页列表中
- 已打开的 iframe 会话不会立即中断,但下次 SSE 请求会被网关拒绝(403)

5.4 注意事项

- 分享页当前不支持删除——如不再需要,用「禁用」使其对用户不可见
- 修改 `is_public` 需通过 API(管理界面暂未提供此开关)
- 一个 RAGFlow 资源 ID 可以关联多个分享页(不同名称、不同授权对象)

6. 授权管理

6.1 概念

授权是把"某个分享页的访问权"赋予"某个用户或用户组"的操作。

- `subject_type='user'`:直接授权给某个用户
- `subject_type='group'`:授权给某个用户组,组内成员继承权限

授权创建写审计日志(`grant_create`),撤销写 `grant_revoke`。

6.2 创建授权

1. 进入 sidebar 「授权管理」
2. 顶部表单中:
 - **分享页**:下拉选择要授权的分享页
 - **主体类型**:用户 / 用户组
 - **授权对象**:根据主体类型,下拉选择具体用户或用户组
3. 点「授权」按钮

授权立即生效。用户下次刷新分享页列表即可看到新授权的分享页。

6.3 撤销授权

在授权列表中,每行右侧有「撤销」按钮:

- 撤销后,网关立即吊销该用户/组对该分享页的所有 T_short
- 用户已打开的 iframe 下次 SSE 请求返回 403(grant 校验失败)
- 撤销不删除历史会话记录(管理员仍可在会话管理中查看)

6.4 注意事项

- 授权是幂等的:重复授权同一个(分享页 + 用户/组)不会创建重复记录
- 撤销授权后,用户的历史会话不删除——如果想彻底清理,需到「会话管理」手动删除该用户的会话
- 用户组授权 + 用户直接授权可以共存,撤销其中一个不影响另一个

7. 会话管理

7.1 概念

会话是用户在分享页中与 RAGFlow 的对话记录。每个会话:

- 归属一个用户和一个分享页
- 有标题(首次提问后自动用首问内容命名,用户可重命名)
- 有创建时间和最后活跃时间

- 有消息数(从 RAGFlow history 同步)

管理员可以跨用户查看所有会话,按用户、分享页、时间筛选。

7.2 查看会话列表

1. 进入 sidebar 「会话管理」
2. 可选筛选:用户下拉 / 分享页下拉 / 时间范围
3. 列表显示:会话标题、所属用户、分享页、消息数、创建时间、最后活跃时间

7.3 查看会话正文

点会话行的「查看正文」按钮,管理员可查看该会话的完整消息内容与引用。
此操作写审计日志(`session_view_elevated`),记录管理员查看用户会话的越权访问行为。

7.4 注意事项

- 管理员查看会话正文是审计行为,每次查看都写日志
- 会话删除由用户在前端发起(用户删除自己的会话),管理员不直接删除会话;如需删除,可通过 API 调用

8. 审计日志

8.1 概念

审计日志记录所有敏感操作,永久保留,不自动清理。覆盖的操作类型:

action	含义
<code>login_success</code>	登录成功
<code>login_failure</code>	登录失败
<code>grant_create</code>	创建授权
<code>grant_revoke</code>	撤销授权
<code>session_delete</code>	删除会话
<code>session_view_elevated</code>	管理员查看用户会话正文
<code>user_password_change</code>	修改用户密码
<code>user_enable</code>	启用用户
<code>user_disable</code>	禁用用户
<code>public_chat</code>	公开分享页访问(可配置关闭)

8.2 查看审计日志

1. 进入 sidebar 「审计日志」
2. 筛选:
 - **操作者:**下拉选择某个用户(查看该用户的操作记录)

- **操作类型**:下拉选择具体 action(如只看 `login_failure`)
- **起始日期 / 结束日期**:按时间范围筛选

3. 点「筛选」按钮

列表显示:时间、操作者、操作类型、目标类型、目标 ID、详情(JSON)。

8.3 注意事项

- 审计日志不可删除,不可修改——它是合规审计的事实源
- `public_chat` 默认开启,可通过 `PUBLIC_AUDIT_ENABLED=false` 关闭(节省存储)
- 日志按时间倒序显示(最新在前),默认显示最近 100 条

附:常见问题

Q: 创建用户后,用户能自己改密码吗?

A: 不能。所有密码修改都需管理员通过「改密码」按钮操作。

Q: 撤销授权后,用户已打开的对话会怎样?

A: iframe 不会自动关闭,但下次发消息(SSE 请求)会返回 403,提示"无权访问该分享页"。用户刷新页面后,该分享页从列表消失。

Q: 禁用用户后,用户正在进行的对话会立即中断吗?

A: 下次 SSE 请求会被网关拒绝(403,用户已禁用)。正在进行的那一轮对话可能完成,但下一轮提问会被拒绝。

Q: 删除用户后,RAGFlow 侧的会话记录会删除吗?

A: 门户侧记录全部删除。RAGFlow 侧会尝试删除(APIConversation),失败的会话保留在 RAGFlow 中,需管理员后续手动清理。门户侧不留孤儿记录。

Q: 如何查看某个用户的所有操作记录?

A: 审计日志页,操作者下拉选择该用户,点筛选。

Q: 分享页和用户组能删除吗?

A: 当前都不支持删除。不再需要时,分享页用「禁用」,用户组移除所有成员。